

System Security Plan (SSP)

Orion Citizen Services Platform (OCSP)

Organization: Orion Government Solutions
System ID: OCSP-001
Document Version: 1.0
Document Status: Draft
Document Owner: System Owner — Orion Citizen Services Platform
Prepared By: Junior GRC Analyst
Assessment Boundary: Orion Citizen Services Platform
Environment: Hybrid Cloud / Azure Government / Microsoft 365
Review Frequency: At least annually and after significant system changes
Date: July 2026

Document Control

Version	Date	Author	Description	Status
1.0	July 2026	Junior GRC Analyst	Initial System Security Plan	Draft

Approval

Role	Name	Approval Status
System Owner	Director of Government Platforms	Pending
Information System Security Officer	Assigned Security Officer	Pending
Chief Information Security Officer	CISO	Pending
Authorizing Official	Designated Authorizing Official	Pending

1. Executive Summary

The Orion Citizen Services Platform (OCSP) is an information system operated by Orion Government Solutions to support government-facing and citizen-related service operations.

The system processes, stores, and transmits customer and citizen information and operates within a regulated environment. OCSP uses a hybrid cloud architecture consisting of workloads hosted in Azure Government, organizational services provided through Microsoft 365, corporate

infrastructure, remote workforce access, and connections to approved third-party vendors and external government systems.

The purpose of this System Security Plan is to document the security architecture, system environment, authorization boundary, information types, users, operational responsibilities, and security control implementation approach for the Orion Citizen Services Platform.

This document serves as a foundational component of the system's authorization package and provides the basis for subsequent security assessment and authorization activities.

The system is subject to security, privacy, contractual, organizational, and regulatory requirements applicable to the information processed and the services provided by Orion Government Solutions.

2. System Identification

2.1 General Information

Attribute	Description
System Name	Orion Citizen Services Platform
System Acronym	OCSP
System ID	OCSP-001
Organization	Orion Government Solutions
System Type	Hybrid Cloud Information System
Primary Cloud Environment	Azure Government
Productivity and Collaboration Platform	Microsoft 365
System Owner	Director of Government Platforms
Security Officer	Assigned Information System Security Officer
Authorizing Official	Designated Orion Government Solutions Authorizing Official
Primary Business Function	Citizen and government service operations
Workforce Model	Hybrid and remote
System Status	Operational / Under Authorization Review

2.2 System Purpose

The Orion Citizen Services Platform supports the delivery and management of government-related services involving customer and citizen information.

The system provides capabilities that may include:

- Citizen service request management
- Customer record management
- Government customer interactions
- Secure information exchange
- Internal service administration
- Operational reporting
- System administration
- Integration with approved external systems

The system is designed to support authorized users while protecting the confidentiality, integrity, and availability of information processed by the platform.

3. System Categorization

3.1 Information Types

The system may process or store the following information types:

Information Type	Description	Sensitivity
Citizen Information	Information associated with individuals receiving or requesting services	Sensitive
Customer Information	Information associated with government customers and organizational users	Sensitive
Authentication Information	User identity and authentication-related information	Sensitive
Operational Information	Information required to operate and administer the platform	Internal
Audit Information	Security and system activity logs	Sensitive
Business Information	Orion operational and service-related information	Internal / Sensitive
Security Information	Configuration, vulnerability, and security monitoring information	Sensitive

Information classification and handling requirements are determined according to applicable Orion Government Solutions policies, contractual obligations, and regulatory requirements.

3.2 Security Objectives

The security objectives of OCSP are:

Confidentiality

Protect information from unauthorized access, disclosure, or use.

Integrity

Protect information from unauthorized modification, destruction, or manipulation.

Availability

Ensure authorized users can access required services and information when needed.

3.3 Risk Considerations

The system's risk profile is influenced by:

- Processing of citizen and customer information
- Hybrid cloud architecture
- Remote workforce access
- Reliance on cloud infrastructure
- Third-party vendors and service providers
- External system connections
- Privileged administrative access
- Potential cyber threats targeting government-related environments
- Dependence on identity and authentication services

These risk considerations are addressed through organizational policies, security controls, monitoring, assessments, incident response, contingency planning, and continuous improvement activities.

4. System Description

4.1 System Overview

The Orion Citizen Services Platform is a hybrid cloud system supporting government and citizen service operations.

The system consists of application services, databases, identity services, supporting infrastructure, security monitoring capabilities, administrative interfaces, and external connections.

The system uses Azure Government as the primary cloud hosting environment for applicable workloads and Microsoft 365 for organizational collaboration, communication, and supporting business services.

Authorized personnel may access system resources from corporate locations or approved remote environments.

4.2 System Components

The system includes or depends upon the following component categories:

Application Components

- Citizen service applications
- Customer-facing interfaces
- Administrative interfaces
- Application programming interfaces
- Supporting application services

Data Components

- Application databases
- Structured and unstructured data repositories
- Backup storage
- Audit log repositories

Infrastructure Components

- Virtual machines
- Containers where applicable
- Networking components
- Storage services
- Security services
- Management services

Identity Components

- Centralized identity services
- Authentication services
- Multi-factor authentication
- Privileged access mechanisms
- Role-based access management

Security Components

- Security monitoring
- Vulnerability management
- Endpoint security
- Logging and alerting
- Incident response capabilities

Supporting Services

- Microsoft 365 services
- Corporate network services
- Approved third-party services
- Managed service providers

5. System Environment

5.1 Azure Government Environment

Azure Government provides the primary cloud environment for applicable OCSP workloads.

The Azure Government environment may host:

- Application services
- Databases
- Virtual infrastructure
- Storage
- Network components
- Security monitoring capabilities
- Backup services
- Administrative services

Cloud infrastructure security responsibilities are divided between Orion Government Solutions and the cloud service provider according to the applicable shared responsibility model and contractual arrangements.

Orion Government Solutions remains responsible for security responsibilities assigned to the organization, including appropriate configuration, identity management, access control, data protection, system administration, monitoring, and governance activities.

5.2 Microsoft 365 Environment

Microsoft 365 supports organizational collaboration and productivity activities.

Relevant services may include:

- Email
- Collaboration
- Document management
- Internal communication
- Security and compliance capabilities

Microsoft 365 services may support OCSF operations but are not automatically considered part of the OCSF authorization boundary unless explicitly included in the system boundary.

Dependencies on Microsoft 365 are documented and managed according to applicable organizational security requirements.

5.3 Corporate Environment

The corporate environment provides supporting services for:

- Workforce identity
- Endpoint management
- Administrative access
- Security operations
- Business operations
- Network connectivity

Corporate systems that directly support OCSF are documented as system dependencies.

5.4 Remote Workforce

Orion Government Solutions supports a hybrid and remote workforce.

Remote access to system resources is permitted only through approved access mechanisms and is subject to applicable security requirements.

Remote access security measures may include:

- Multi-factor authentication
- Managed endpoints
- Endpoint security controls
- Secure remote access mechanisms
- Role-based access
- Session monitoring where applicable
- Access logging

Users are responsible for complying with organizational requirements when accessing company systems remotely.

6. System Boundary

6.1 Authorization Boundary

The OCSF authorization boundary includes the components, services, infrastructure, and personnel directly responsible for operating and securing the Orion Citizen Services Platform.

The authorization boundary includes:

- OCSF application services
- OCSF databases
- OCSF storage resources
- OCSF virtual infrastructure
- OCSF application programming interfaces
- System authentication integrations
- System administration interfaces
- System logging and monitoring capabilities
- System backup and recovery components
- Security services directly supporting OCSF

6.2 External Systems and Services

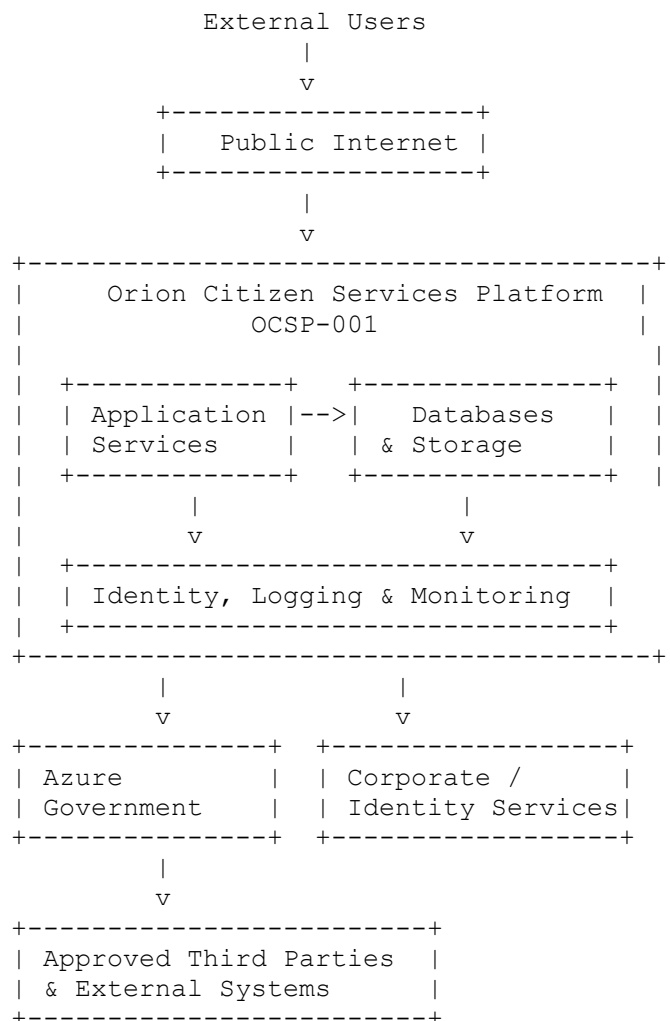
The following systems and services may interact with or support OCSF but are external to the authorization boundary unless specifically incorporated:

- General public internet
- External government systems
- Third-party vendor systems
- Managed service provider environments
- External software-as-a-service platforms
- User-owned home networks
- Unmanaged personal devices
- External telecommunications providers

External connections are subject to documented authorization, security requirements, contractual controls, and appropriate monitoring.

6.3 Boundary Diagram

The following logical representation describes the system boundary:



7. System Interconnections

OCSF may exchange information with approved external systems and services.

Examples include:

- Government customer systems
- Identity providers
- Cloud services
- Managed service providers
- Security service providers
- Approved software vendors

All system interconnections must be:

- Documented
- Approved
- Configured securely
- Monitored where appropriate
- Reviewed periodically

The organization maintains appropriate documentation for system interconnections and associated security responsibilities.

8. Users and Roles

8.1 User Categories

External Citizens and Customers

External users may access approved service interfaces to submit requests or interact with authorized services.

Government Customer Users

Government customer personnel may access system capabilities based on approved organizational requirements.

Orion Employees

Employees may access system resources based on job responsibilities and approved access requirements.

System Administrators

System administrators perform authorized infrastructure, application, and platform administration activities.

Security Personnel

Security personnel monitor, investigate, and respond to security events.

Vendor Personnel

Approved third-party personnel may receive limited access where required to perform authorized contractual services.

Vendor access must be:

- Business justified
- Approved
- Time limited where practical
- Appropriately monitored
- Removed when no longer required

9. Roles and Responsibilities

9.1 Authorizing Official

The Authorizing Official is responsible for:

- Making the authorization decision
- Accepting or rejecting identified risks
- Reviewing security assessment results
- Reviewing outstanding POA&M items
- Ensuring risks are managed at the appropriate organizational level

9.2 System Owner

The System Owner is responsible for:

- Operating the system
- Ensuring system security requirements are addressed
- Supporting risk management activities
- Ensuring appropriate resources are available
- Approving system documentation
- Coordinating remediation activities

9.3 Chief Information Security Officer

The CISO provides organizational security leadership and oversight.

Responsibilities may include:

- Establishing security strategy
- Providing security governance
- Supporting risk management
- Reviewing significant security risks
- Supporting incident response and security operations

9.4 Information System Security Officer

The security officer supports the day-to-day security activities of the system.

Responsibilities include:

- Supporting control implementation
- Coordinating security assessments
- Monitoring security documentation
- Supporting vulnerability and incident management
- Coordinating evidence collection

9.5 Junior GRC Analyst

The Junior GRC Analyst supports the RMF lifecycle by:

- Maintaining RMF documentation
- Tracking control implementation status
- Coordinating evidence collection
- Maintaining evidence inventories

- Supporting assessment preparation
- Tracking findings
- Maintaining POA&M information
- Supporting continuous monitoring activities
- Maintaining traceability between controls, evidence, findings, and remediation

The Junior GRC Analyst does not independently approve risk acceptance or make the final authorization decision.

9.6 Control Owners

Control Owners are responsible for:

- Implementing assigned security controls
- Maintaining required procedures
- Providing evidence
- Supporting assessments
- Remediating identified weaknesses

9.7 System Administrators

System administrators are responsible for:

- Secure system configuration
- System maintenance
- Access administration
- Change implementation
- Technical security operations

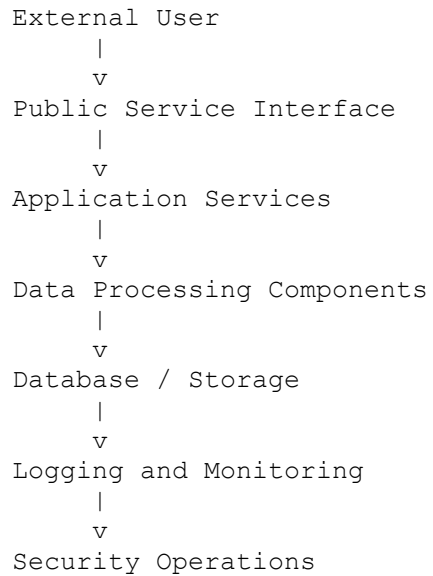
9.8 Third-Party Providers

Third-party providers are responsible for meeting applicable contractual and security requirements.

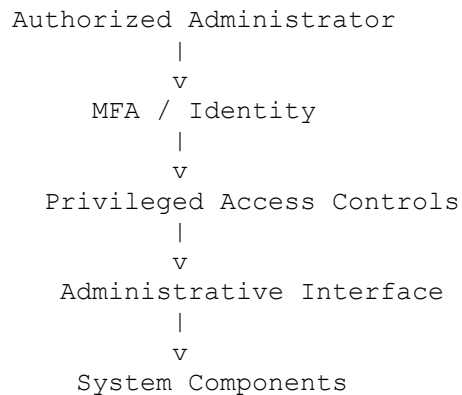
Third-party responsibilities must be documented and monitored according to the organization's vendor risk management processes.

10. Data Flow Overview

The general information flow is:



Administrative access follows a separate controlled pathway:



11. Security Control Implementation Summary

The following sections describe the organization's general approach to implementing security controls.

Detailed control-level implementation statements and evidence references are maintained in the control implementation matrix.

11.1 Access Control

OCSP restricts access to authorized users and processes.

Access is based on:

- Business need
- Job responsibilities
- Approved roles
- Least privilege principles

Privileged access is restricted to authorized personnel and is subject to enhanced security requirements.

User access is reviewed periodically and modified or removed when no longer required.

Primary Evidence Examples:

- Access control policy
- Role-permission matrix
- Access approval records
- Periodic access review records
- Privileged access reports

Control Owners:

- Identity and Access Management Team
- System Owner

11.2 Awareness and Training

Personnel with access to OCSP are required to complete applicable security awareness and role-based training.

Training requirements may include:

- Security awareness training
- Phishing awareness
- Acceptable use requirements
- Privacy and data handling
- Role-specific security responsibilities

Training completion is tracked through organizational processes.

Primary Evidence Examples:

- Training policy
- Training completion records
- Security awareness materials

Control Owner:

- Human Resources / Security Awareness Program
-

11.3 Audit and Accountability

OCSP generates and maintains appropriate security and operational logs.

Logging capabilities support:

- User activity monitoring
- Administrative activity monitoring
- Security event detection
- Incident investigation
- Accountability

Logs are protected against unauthorized modification and are retained according to applicable organizational requirements.

Primary Evidence Examples:

- Logging configuration
- Log retention settings
- Security monitoring records
- Sample audit logs
- Alert configuration

Control Owner:

- Security Operations Team
-

11.4 Assessment, Authorization, and Monitoring

The system is subject to security assessment and authorization activities.

The organization:

- Documents system security requirements
- Performs security assessments
- Documents assessment findings
- Tracks weaknesses through the POA&M
- Conducts remediation activities
- Performs ongoing monitoring

Assessment results are provided to appropriate stakeholders for risk management and authorization decisions.

Primary Evidence Examples:

- System Security Plan
- Security Assessment Plan
- Security Assessment Report
- POA&M
- Continuous monitoring reports

Control Owner:

- GRC and Security Risk Management Function
-

11.5 Configuration Management

OCSP components are managed through configuration management processes.

Configuration management activities include:

- Establishing configuration baselines
- Managing system changes
- Approving changes
- Tracking configuration modifications
- Reviewing unauthorized changes

Significant system changes are evaluated for potential security impact.

Primary Evidence Examples:

- Configuration baselines
- Change tickets

- Change approval records
- Configuration review records

Control Owner:

- Infrastructure and Platform Engineering
-

11.6 Contingency Planning

The organization maintains contingency and recovery capabilities for critical system functions.

Contingency planning activities include:

- Backup operations
- Recovery procedures
- System restoration
- Business continuity planning
- Disaster recovery testing

Recovery capabilities are reviewed and tested according to organizational requirements.

Primary Evidence Examples:

- Contingency plan
- Backup reports
- Recovery test records
- Disaster recovery exercise documentation

Control Owner:

- Infrastructure and Business Continuity Teams
-

11.7 Identification and Authentication

OCSP requires users and processes to be appropriately identified and authenticated before access is granted.

Authentication capabilities include:

- Centralized identity management
- Multi-factor authentication

- Account lifecycle management
- Privileged access controls

Authentication requirements vary according to user role, access type, and system risk.

Primary Evidence Examples:

- Authentication configuration
- MFA enforcement report
- Identity policy
- Account management records

Control Owner:

- Identity and Access Management Team
-

11.8 Incident Response

The organization maintains incident response capabilities for detecting, reporting, analyzing, containing, and recovering from security incidents.

Incident response activities include:

- Incident detection
- Triage
- Investigation
- Escalation
- Containment
- Eradication
- Recovery
- Lessons learned

Security incidents are documented according to organizational procedures.

Primary Evidence Examples:

- Incident response plan
- Incident tickets
- Incident response exercise records
- Contact and escalation procedures

Control Owner:

- Security Operations and Incident Response Team

11.9 Maintenance

System maintenance activities are performed by authorized personnel.

Maintenance activities are:

- Authorized
- Documented where required
- Performed using approved procedures
- Reviewed for security impact

Remote maintenance is subject to appropriate access and authentication requirements.

Primary Evidence Examples:

- Maintenance procedures
- Maintenance tickets
- Remote maintenance records
- Administrative access logs

Control Owner:

- Infrastructure and Platform Engineering
-

11.10 Media Protection

Information stored on system media is protected according to applicable data classification and handling requirements.

Media protection activities may include:

- Access restrictions
- Encryption
- Secure disposal
- Media tracking where required

Primary Evidence Examples:

- Media handling policy
- Encryption configuration
- Disposal records

Control Owner:

- Information Security and IT Operations
-

11.11 Physical and Environmental Protection

Physical infrastructure supporting the system is protected through appropriate physical and environmental security controls.

Where cloud infrastructure is used, applicable physical security responsibilities are managed through the cloud provider's controls and contractual arrangements.

Orion remains responsible for physical security of organizational facilities and equipment under its direct control.

Primary Evidence Examples:

- Physical security policies
- Facility access records
- Cloud provider security documentation

Control Owner:

- Facilities and IT Operations
-

11.12 Planning

Security planning is integrated into system operations and lifecycle activities.

Security planning activities include:

- Maintaining this SSP
- Documenting system boundaries
- Identifying dependencies
- Defining security responsibilities
- Reviewing significant changes

Control Owner:

- System Owner
- GRC Function

11.13 Personnel Security

Personnel security processes support the secure lifecycle of individuals with system access.

Activities may include:

- Screening where required
- Role assignment
- Access authorization
- Transfer procedures
- Termination procedures

Access is modified or removed when personnel no longer require system access.

Primary Evidence Examples:

- Personnel security procedures
- Termination checklists
- Access removal records

Control Owner:

- Human Resources
- Identity and Access Management

11.14 Risk Assessment

Security risks are identified, analyzed, and monitored throughout the system lifecycle.

Risk assessment activities include:

- Threat identification
- Vulnerability identification
- Impact analysis
- Risk analysis
- Risk treatment

Risk information supports control selection, remediation, and authorization decisions.

Control Owner:

- GRC and Risk Management Function
-

11.15 System and Services Acquisition

Security requirements are considered when acquiring systems, services, software, and technology.

Third-party services are evaluated based on:

- Security requirements
- Business requirements
- Data sensitivity
- Vendor risk
- Contractual obligations

Control Owner:

- Procurement
 - Vendor Risk Management
 - Information Security
-

11.16 System and Communications Protection

OCSP protects communications and system interfaces through appropriate security mechanisms.

Security protections may include:

- Network segmentation
- Encryption
- Secure protocols
- Boundary protections
- Access restrictions
- Monitoring

External connections are documented and approved.

Primary Evidence Examples:

- Network diagrams
- Firewall rules
- Encryption configuration

- Connection approval records

Control Owner:

- Network and Security Engineering
-

11.17 System and Information Integrity

OCSP uses processes to identify and address threats to system and information integrity.

Activities include:

- Vulnerability scanning
- Malware protection
- Patch management
- Security monitoring
- Error handling
- Incident response

Identified vulnerabilities are prioritized and tracked through remediation processes.

Primary Evidence Examples:

- Vulnerability scan reports
- Patch reports
- Endpoint security reports
- Security alerts
- Remediation tickets

Control Owner:

- Security Operations
 - Infrastructure Engineering
-

11.18 Supply Chain Risk Management

Orion Government Solutions recognizes that third-party vendors and service providers may introduce security and operational risks.

Supply chain risk management activities include:

- Vendor assessment
- Contractual security requirements
- Third-party risk reviews
- Service monitoring
- Review of critical dependencies

Vendor access and services are reviewed based on business need and risk.

Primary Evidence Examples:

- Vendor risk assessments
- Contracts
- Security questionnaires
- Third-party review records

Control Owner:

- Vendor Risk Management
- Procurement
- Information Security

12. System Security Responsibilities

Security responsibilities are divided among Orion Government Solutions, system personnel, cloud service providers, and third-party providers.

Responsibility	Orion	Cloud Provider	Third Party
System configuration	Responsible	Shared	Where applicable
User access management	Responsible	Shared	Where applicable
Data protection	Responsible	Shared	Contractual
Physical cloud infrastructure	Oversight	Responsible	N/A
Application security	Responsible	Shared	Where applicable
Security monitoring	Responsible	Shared	Contractual
Incident response	Responsible	Shared	Contractual
Vulnerability management	Responsible	Shared	Where applicable
Vendor security	Responsible	N/A	Responsible for own environment

Responsibilities must be further documented where shared responsibility exists.

13. Security Documentation and Evidence

The following evidence categories support the security implementation of OCSF:

```
/docs/rmf/ssp/  
    SSP-OCSF-v1.0.md  
  
/docs/rmf/sap/  
    SAP-OCSF-v1.0.md  
  
/docs/rmf/sar/  
    SAR-OCSF-2026-07.md  
  
/docs/rmf/poam/  
    POAM-OCSF-2026-07.md  
  
/evidence/  
    AC/  
    AT/  
    AU/  
    CA/  
    CM/  
    CP/  
    IA/  
    IR/  
    MA/  
    MP/  
    PE/  
    PL/  
    PS/  
    RA/  
    SA/  
    SC/  
    SI/  
    SR/
```

Evidence must be:

- Relevant
- Current
- Traceable to a control
- Protected from unauthorized modification
- Maintained according to organizational requirements

14. Control Implementation Status

The following status categories are used to track control implementation:

Status	Definition
Implemented	Control is implemented and supporting evidence is available
Partially Implemented	Control is implemented in part but requires additional work
Planned	Control implementation has been approved but is not yet complete
Not Implemented	Control has not yet been implemented
Not Applicable	Control does not apply based on documented justification
Other Than Satisfied	Assessment identified a deficiency in control implementation or operation

Detailed status is maintained in the control implementation matrix.

15. Security Control Traceability

Security controls are linked to supporting documentation and evidence.

Example:

```

Control
  |
  v
SSP Implementation Statement
  |
  v
Evidence
  |
  v
Assessment Procedure
  |
  v
Assessment Result
  |
  v
Finding
  |
  v
POA&M Remediation

```

Example:

```

AC-2 Account Management
  |
  v
SSP:
Accounts are managed through documented lifecycle procedures.
  |

```

v
Evidence:
EVD-AC-001
|
v
SAP:
Review account lifecycle and inactive account management.
|
v
SAR:
Inactive accounts were not consistently disabled.
|
v
POA&M:
POAM-001
|
v
Remediation:
Automate account lifecycle management.

16. System Security Plan Maintenance

This SSP must be reviewed:

- At least annually
- After significant system changes
- After major architectural changes
- After significant security incidents
- After changes to system ownership
- When applicable regulatory or organizational requirements change

Changes to the system that may require SSP updates include:

- New system components
 - Major cloud architecture changes
 - New external connections
 - Significant changes to data types
 - Major changes to system functionality
 - Changes to security responsibilities
 - Significant changes to third-party services
-

17. Known Security Risks and Dependencies

The following risks and dependencies are recognized:

Risk / Dependency	Description	Management Approach
Cloud Dependency	OCSF depends on Azure Government services	Cloud security responsibilities and availability planning
Identity Dependency	System access depends on identity services	MFA, access reviews, lifecycle management
Remote Workforce	Users access systems from remote environments	Secure access, endpoint protection, authentication
Third-Party Vendors	Vendors may support system operations	Vendor risk management and contractual controls
External Connections	OCSF may exchange data with external systems	Approved and monitored interconnections
Sensitive Information	System processes citizen and customer information	Access control, monitoring, protection, and handling requirements
Availability Requirements	Service interruption may impact government operations	Backup, recovery, and contingency planning

18. System Security Plan Conclusion

The Orion Citizen Services Platform is a hybrid cloud information system that supports government-related service operations and processes sensitive customer and citizen information.

The system operates within a complex environment involving Azure Government, Microsoft 365, corporate infrastructure, remote users, third-party providers, and external systems.

This System Security Plan documents the system's purpose, architecture, boundary, users, dependencies, responsibilities, and security control implementation approach.

The SSP serves as the baseline for:

- Security assessment planning
- Security control testing
- Assessment reporting
- POA&M development
- Authorization activities
- Continuous monitoring

Security control implementation and effectiveness must be validated through formal assessment activities.

Document Status

Current Version: 1.0

Status: Draft

Next Related Document: Security Assessment Plan (SAP)

Related System: Orion Citizen Services Platform (OCSP-001)

Related Organization: Orion Government Solutions